

04 — Custody & Key Management

This document states OlomiPay's custody position **accurately**. Overstating "non-custodial" to a partner or regulator is a misrepresentation; the design below is custodial and is described as such.

1. Custody position (plain statement)

OlomiPay operates a CUSTODIAL USD-denominated wallet. The operator has the technical ability to control user funds. OlomiPay is therefore responsible for safeguarding client assets and applies AML/KYC and security controls to that standard (Docs 05 & 06).

2. How user wallets are created

Each user has an individual Stellar account holding USDC. The keypair is **deterministically derived** from a single server-side master secret and the user's phone number:

```
seed      = HMAC-SHA256(WALLET_DERIVATION_SECRET, "olomipay-wallet-v1:" + phone)
keypair   = ed25519(seed)
```

Implications, stated plainly: - The operator, holding WALLET_DERIVATION_SECRET, can **re-derive any user's private key from their phone number** — no user PIN required. This is what makes the model **custodial**, and it powers **phone-based account recovery** (a user who reinstalls or changes device regains the same wallet + funds). - The user's stored secret is **also** kept encrypted at rest (defence in depth, below), but the operator does not depend on that copy.

3. Encryption at rest (defence in depth)

The user's secret key is additionally stored encrypted with **AES-256-GCM**, where the key is derived as:

```
encKey = PBKDF2(userPIN, salt = SHA256(phone + ENCRYPTION_KEY), 310,000, SHA-512)
```

- This protects the stored copy against an attacker who steals the **database but not** the server secrets.
- PINs themselves are never stored — only **bcrypt** hashes (cost 12).
- It does **not** make the system non-custodial (see §2).

4. Platform-controlled wallets

Wallet	Purpose	Control
Gas wallet	Sponsors account reserves + pays network fees (fee-bump)	Platform
Fee wallet	Collects the ~1% platform fee (own USDC trustline)	Platform

Savings vault	Holds funds placed into savings/goals	Platform
Treasury (as configured)	Settlement / payouts	Platform

Savings/goal balances **sit in a platform-controlled wallet** and payouts are platform-signed — explicitly custodial for that portion.

5. Transaction signing

- **User-initiated transfers** (send, withdraw, savings deposit, agent cash-out) require the user's **PIN**, which authorises decryption/derivation and signing.
- **Platform-initiated payouts** (savings/goal withdrawals, fee sweeps, partner settlement) are signed by platform-controlled wallets.
- Server-side **risk screening** and **tier-limit checks** run before signing.

6. Reserves & solvency

- User balances are backed 1:1 by USDC held on Stellar.
- An automated **reconciliation** check compares platform USDC holdings against aggregate user liabilities every monitoring cycle and **alerts** if holdings fall below liabilities (see Doc 05/06).

7. Key risk concentration & safeguards

WALLET_DERIVATION_SECRET (and ENCRYPTION_KEY) are the highest-value secrets: compromise of the derivation secret would expose **all** user funds. Controls:

Control	Status
Secrets stored as environment variables, access-restricted	In place
Separation of gas vs. fee wallets	In place
Rotation support for the at-rest encryption key (ENCRYPTION_KEY_PREVIOUS)	In place
Move master key/signing into a dedicated KMS/HSM-backed signer	Planned / recommended
Least-privilege access to production secrets; audit of access	[state current status]
Periodic security review / penetration test	[planned / done — fill in]

Roadmap note: isolating signing into a KMS/HSM service (so application servers never see raw user keys) is the top security hardening item and is recommended before scaling balances.

8. Summary for the reviewer

- Model: **custodial** wallet, USD value held as USDC on Stellar.
- Operator control: yes (deterministic derivation + platform vaults).
- User authorisation: PIN-gated for user-initiated movements.
- Safeguarding: 1:1 USDC backing + automated reconciliation + at-rest encryption.
- Primary residual risk: master-secret concentration — mitigation roadmap above.